Frank Henry

Comprehensive Security Audit for

Eastline Cleaning LLC.

10/12/26

Executive Summary

This comprehensive security audit will be written for the company **Eastline Cleaning LLC.** This company is a cleaning service company providing services such as waste removal, garbage and recycling bin cleaning, and exterior powerwashing. This company deals with personal client information such as credit card transactions, home addresses, phone numbers, and email addresses. We'll identify existing vulnerabilities and evaluate the company's current stage of security across the NIST Frameworks, ISO 27001, and OWASP Top 10. We will provide security recommendations based on our findings.

Company Overview

Category	Description
Industry	Waste Management
Employees	10
Operations	Cloud-hosted website and app
Data Processed	Customer payment information, physical home addresses, phone numbers and emails
Cloud Provider	AWS
Primary Concerns	Data breaches, phishing and mishing, stolen information, potential physical threats

Many customers subscribe to recurring weekly or monthly plans, so Eastline keeps payment methods, addresses and service schedules on file long term. There is no dedicated IT team or security employee.

Network and Infrastructure Security

The office setup is a typical small business setup. They have 1 consumer-grade router, WiFi, a few Microsoft OS PC's, and 1 shared printer. There's no servers on-site, and everything is set up through the cloud.

Our security recommendations for this setup are:

Control	**Description**	**Justification**

Router/Firewall	Enable firewall rules for the router	This prevents any outside entrance from malicious behavior
Network Segmentation	Separate device networks and deploy firewalls with custom rules between each	This prevents lateral network movement if an attacker gains access to one network
Endpoints (Office PC's)	Require automatic updates be installed on every company device	This ensures the devices each have the newest & latest security updates
Remote Work	Ensure that employees only use company issued devices that can be monitored remotely	If employees' company devices can be monitored remotely, it gives the IT team access from anywhere to monitor the systems.
Centralized Logging	Using Splunk or Wazuh for monitoring	These SIEMs create logs for suspicious behavior to be reviewed and prevented by SOC teams

Company risk rating before implementing security rules: **HIGH**
Company risk rating after implementing security rules: **LOW**

Application and Web Security

Eastline's main store front is its website and app. These are the easiest way for the company to market and gain clients. Any vulnerabilities can lead to malicious behavior, and we are assessing their website and app against OWASP's Top 10 security concerns. OWASP's list is:

1. A01:2025 - Broken Access Control
2. A02:2025 - Security Misconfiguration
3. A03:2025 - Software Supply Chain Failures
4. A04:2025 - Cryptographic Failures
5. A05:2025 - Injection
6. A06:2025 - Insecure Design
7. A07:2025 - Authentication Failures
8. A08:2025 - Software or Data Integrity Failures
9. A09:2025 - Security Logging and Alerting Failures
10. A10:2025 - Mishandling of Exceptional Conditions

Category	Eastline exposure	Rating	Recommendation
Broken Access Control	Admin login page is public; a customer portal (if used) may expose other customers' invoices by changing an ID in the URL	**High**	Restrict admin by IP or SSO; check authorization on every request
Security Misconfiguration	Missing security headers (HSTS, CSP, X-Frame-Options); default CMS settings; detailed error messages	**High**	Harden hosting; add headers; disable unused features
Software Supply Chain Failures	Outdated CMS core, themes and plugins; third-party scripts on booking pages	**High**	Auto-update; remove unused plugins; inventory scripts
Cryptographic Failures	HTTPS on most pages; customers sometimes email card details	**Medium**	Force HTTPS sitewide; never accept cards by email
Injection	Quote and contact forms not tested for SQL injection or cross-site scripting (XSS)	**Medium**	Validate input; use parameterized queries and output encoding
Insecure Design	Booking form collects gate codes in plain fields; no rate limiting or CAPTCHA	**Medium**	Collect only what is needed; add CAPTCHA and rate limits

Authentication Failures	Shared admin password, no MFA, no lockout after failed logins	**High**	Individual admin accounts with MFA; login lockout
Software or Data Integrity Failures	Plugins from unofficial sources; scripts loaded without integrity checks	**Medium**	Official sources only; Subresource Integrity (SRI)
Security Logging and Alerting Failures	No record or alert for failed logins or admin changes	**Medium**	Security plugin or host logging with email alerts
Mishandling of Exceptional Conditions	Payment or form errors may show stack traces or fail open	**Low**	Generic error pages; fail closed; test error paths

Cryptography and Data Protection

The most sensitive is protected while it sits with its cloud vendor, but once it leaves the cloud, it becomes super sensitive.

Data in Transit: The website, email and SaaS tools use HTTPS/TLS by default. The weak points are human: customers emailing or texting card numbers, and staff emailing customer lists or spreadsheets without encryption.

- Recommendation- Update all SSL certificates and disable legacy ciphers.

Data at Rest: Cloud vendors encrypt stored data. However, office PCs and laptops may lack full-disk encryption, field phones may have no screen lock, and paper job sheets are not encrypted at all.

- Recommendation- Encrypt every device. BitLocker or FileVault on computers, a passcode and built-in encryption on phones.

Password Storage: Strong passwords can help prevent attackers from gaining access, but the most secure method is to enable MFA.

- Recommendation- Use bcrypt or a different encrypted password storage app which requires MFA to gain access.

Key Management: These are credentials that let a program, script or command-line tool act on an AWS account without a username and password.

- Separate keys from application servers.

Incident Response and Risk Management

Eastline should be following the NIST Frameworks for this.

1. **Prepare:** name an incident lead (the owner) and backup; keep a contact list for the IT provider, payment processor, bank, cyber insurer and a lawyer.
2. **Detect and report:** staff report suspicious emails, lost phones or odd account activity to the lead immediately.
3. **Contain:** reset passwords, sign out all sessions, disconnect infected PCs from the network, remote-wipe lost phones.
4. **Recover:** clean or rebuild affected devices; restore data from backups; confirm accounts are secure.
5. **Notify:** work with legal counsel on customer and state notifications; inform the payment processor if card data may be involved.
6. **Learn:** hold a short review and update controls within two weeks.

Cloud & Mobile Security

Almost all of Eastline's data lives in cloud services and on mobile phones, so account security and device control matter more here than anything on the office network.

Cloud services (assumed): email and file storage (Microsoft 365 or Google Workspace), scheduling/CRM (such as Jobber or Housecall Pro), payments (such as Square or Stripe), accounting (such as QuickBooks Online) and payroll.

Under the **shared responsibility model**, the vendor secures its platform, but Eastline is responsible for who can log in, what they can see, and how data is shared.

Recommendations:

1. Enforce MFA for every account owner.
2. Give each employee separate login credentials.
3. Apply least privilege, meaning employees can only see what they need to see and nothing more.
4. Enroll all phones in mobile device management (MDM), such as Microsoft Intune, Google Endpoint Management or Jamf.

Security Policy and Compliance Alignment

Policy	Key rules
Information Security Policy	Owner is accountable; risks reviewed yearly; staff must follow all policies
Acceptable Use Policy	Approved apps only; no customer data on personal accounts; report incidents
Access Control and Password Policy	Individual accounts, MFA, password manager, same-day offboarding
Payment Card Handling Policy	No card numbers on paper, email or text; processor tools only
Mobile Device Policy	MDM enrollment, passcode, report lost devices within 1 hour
Incident Response Plan	The six-step plan in Section 6
Data Retention Policy	What is kept, for how long, and how it is destroyed

Risk Register

Risk	Likelihood	Impact	Owner
Shared accounts and no MFA on cloud services	High	5	CEO
Card data stored outside the payment processor	High	5	Office Manager
No security policy, owner or training	High	4	CEO
Unpatched endpoints without managed protection	High	4	IT provider
Unmanaged field-crew phones	High	4	CEO
Weak website admin authentication	Medium	5	Web developer
No incident response or breach-notification plan	Medium	5	CEO
No tested backups	Medium	5	Office Manager

Insecure router and flat Wi-Fi network	Medium	3	Office Manager
No website logging or alerting	Medium	3	Office Manager
Unencrypted devices and no retention rule	Medium	3	Office Manager

Overall Security Posture

Overall maturity assessment (0 = Non-existent, 1 = Initial, 2 = Weak, 3 = Developing)

Domain	**Maturity Level**
Network	**2**
Application	**2**
Data Protection	**1**
Incident Response	**1**
Cloud Security	**1**
Compliance	**3**

Following our recommendations in this security audit will drastically increase Eastline Cleaning's Web security, leaving clients feeling safer about giving out their personal information.

Conclusion

Overall, this is a small company which seems to be just starting. The company is gaining traction as business ramps up. As a non-technical company, with no IT employees, there would be no way for them to know all the risks that come with running a cloud-based website and app. It is very smart of the company to reach out to us for an audit and review of their current vulnerabilities with some recommended steps to further enhance their cybersecurity, leaving the company and their clients feeling safe about all of the data that gets passed through their website. We feel strongly about this audit, and believe if they follow the recommendations carefully, they will succeed in keeping malicious behavior out of their business.

Final Reflection

As a cybersecurity student, the challenge that most of us have, including myself, is not being an expert yet and knowing everything needed to succeed. But I learned through this assignment more about the consulting field. I learned that there are ways to look into a company's current state of security, and how to provide them with proper recommendations on how to fix the concerns that were found. Personally, I am not into the consulting field as a career myself, I enjoy the technical stuff a lot more. But as always, more knowledge equals more power, so I'm happy that I was able to dive into this and learn more about the consulting side of things.